Penetration Report - Machine "futurevera.thm"

Client:	**futurevera.thm**
Target IP:	10.67.158.174
Test Date:	March 14, 2026
Consultant:	Bender2997_

1. Executive Summary

The objective of this assessment was the IP address 10.67.158.174 associated with the *futurevera.thm* domain, to validate the existence of compromise vectors that could have been exploited by external actors.

A vulnerability for Undocumented Asset Discovery (Shadow IT) was identified through advanced enumeration techniques (*Host Header Fuzzing* and SSL/TLS certificate metadata analysis). This process allowed access to a hidden support *helpdesk* (secrethelpdesk934752.support.futurevera.thm) that lacked strict access controls. The criticality of this finding is classified as High, given that the exposure of an internal, unpatched asset represents a security blind spot leading to system compromise.

2. Metodología y Alcance

Field	Detail
Objective	futurevera.thm web environment
Target IP	10.67.158.174
Scope	Black-Box testing, limited to the identification and exploitation of a single

	critical vulnerability.

Methodology:

An iterative approach was followed: port reconnaissance, initial directory enumeration (unsuccessful Gobuster), and finally, advanced enumeration of subdomains (FFUF) and SSL/TLS certificate analysis to discover hidden assets.

3. Reconnaissance and Discovery Phase

An exhaustive TCP port scan was performed to identify the attack surface.

Nmap Command Used:

nmap -p- -sCV --stats-every=3s 10.67.158.174 --open -T5

Scan Results:

```
Nmap scan report for 10.67.158.174
Host is up (0.067s latency).
Not shown: 65532 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 a8:5f:ee:88:9a:a3:70:5a:12:f7:5a:6d:49:78:78:8d (RSA)
|   256 2b:82:60:ba:fc:06:e9:23:76:d4:28:40:70:bc:cc:76 (ECDSA)
|_  256 fa:da:96:f7:da:33:ad:d5:c7:f0:93:01:75:07:10:9f (ED25519)
80/tcp  open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Did not follow redirect to https://futurevera.thm/
| http-server-header: Apache/2.4.41 (Ubuntu)
443/tcp open  ssl/http Apache httpd 2.4.41 ((Ubuntu))
| tls-alpn:
|_  http/1.1
|_http-title: FutureVera
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=futurevera.thm/organizationName=Futurevera/stateOrProvinceName=Oregon/countryName=US
| Not valid before: 2022-03-13T10:05:19
|_Not valid after:  2023-03-13T10:05:19
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 42.33 seconds
```

Port	State	Service	Version	Notes
80/tcp	Open	http	Apache/X.X.X	Redirection to HTTPS
443/tcp	Open	https	Apache/X.X.X	Certificate analyzed in advanced enumeration phase.

Service Analysis:

Standard directory enumeration was insufficient.

```
┌──(root㉿kali)-[/home/bender]
└─# gobuster dir -w /usr/share/wordlists/dirb/common.txt -u https://futurevera.thm/ -t 100 -k
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://futurevera.thm/
[+] Method:                  GET
[+] Threads:                 100
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 280]
.htaccess            (Status: 403) [Size: 280]
.htpasswd            (Status: 403) [Size: 280]
assets               (Status: 301) [Size: 319] [--> https://futurevera.thm/assets/]
css                  (Status: 301) [Size: 316] [--> https://futurevera.thm/css/]
index.html           (Status: 200) [Size: 4605]
js                   (Status: 301) [Size: 315] [--> https://futurevera.thm/js/]
server-status        (Status: 403) [Size: 280]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

A subdomain enumeration technique, focused on the *Host* header, was then performed.

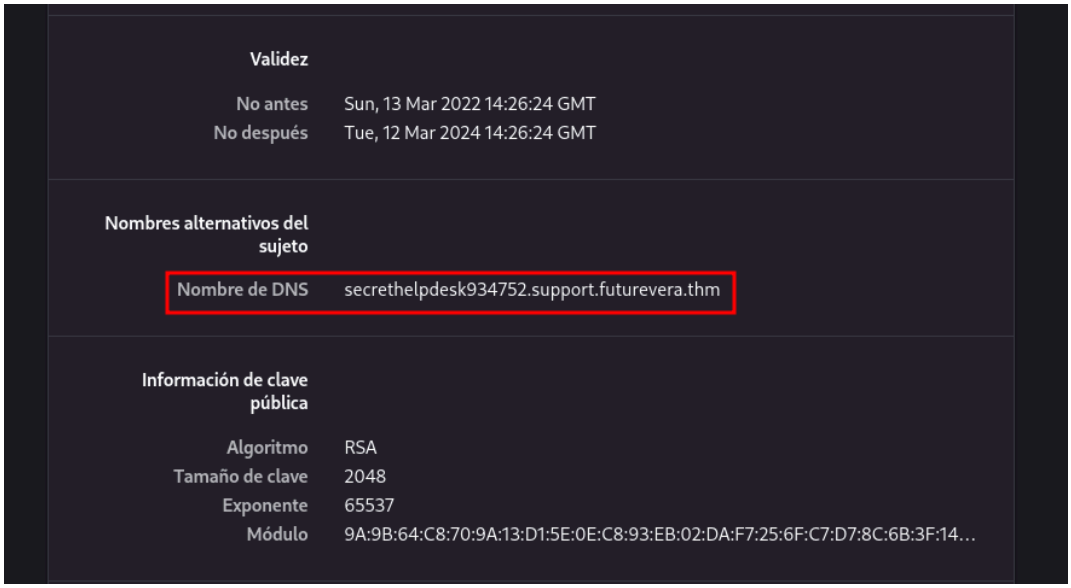
FFUF Command (Host Header Fuzzing):

ffuf -w ./sub_dominios.txt -u http://futurevera.thm -H "Host: FUZZ.futurevera.thm" -v

Result:

```
┌──(root㉿kali)-[/home/bender]
└─# ffuf -w ./sub_dominios.txt -u http://futurevera.thm -H "Host: FUZZ.futurevera.thm" -v

       /'___\  /'___\           /'___\
      /\ \__/ /\ \__/  __  __  /\ \__/
      \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
       \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://futurevera.thm
 :: Wordlist         : FUZZ: /home/bender/sub_dominios.txt
 :: Header           : Host: FUZZ.futurevera.thm
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
________________________________________________

[Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 71ms]
| URL | http://futurevera.thm
| --> | https://futurevera.thm/
    * FUZZ:

[Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 72ms]
| URL | http://futurevera.thm
| --> | https://futurevera.thm/
    * FUZZ: support

:: Progress: [2/2] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

The sub-domain support.futurevera.thm was discovered, and subsequently, through the analysis of the associated SSL/TLS certificate's SAN entries, the specific and hidden *hostname* was obtained:



Discovered Hostname:

secrethelpdesk934752.support.futurevera.thm

4. Finding: Hidden Asset Exposure (Shadow IT)

ID: FV-001

Severity: Critical (High)

CWE: CWE-1004 (Sensitive Data Exposed in Non-Web Structure)

Vulnerability Description:

The system exposes a specific and highly sensitive *hostname* (secrethelpdesk934752.support.futurevera.thm) that is not protected or documented in the main inventory. This asset, a support *helpdesk* system, is publicly accessible without prior network layer authentication and represents a clear case of *Shadow IT*.

Impact:

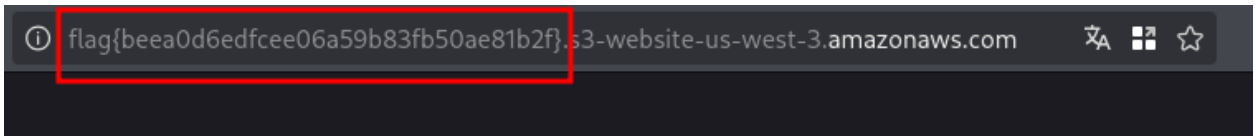
Direct access to the support system, presumably without updated security policies or patches, allowed the acquisition of a compromise indicator (the *flag*) and validation of system compromise without requiring complex exploitation techniques.

Proof of Concept (PoC):

1. **Discovery Phase:** Use of ffuf and SSL/TLS certificate analysis to identify the secret *hostname*.
2. **Resolution:** Addition of the entry 10.67.158.174 secrethelpdesk934752.support.futurevera.thm to /etc/hosts.
3. **Direct Access:** Navigation to the secret *hostname*, which displayed the *helpdesk* content and the validation *flag*, demonstrating null access control.

Flag Obtained (Compromise Indicator):

Flag{beea0d6edfcee06a59b83fb50ae81b2f}



5. Conclusions and Mitigation Recommendations

Conclusion:

The penetration test demonstrated a critical failure in digital asset management. The presence of the hidden and unprotected service is an inherent risk that can be easily exploited by attackers with advanced reconnaissance techniques.

Critical Recommendations (FV-001):

1. **Asset Removal/Isolation (Critical Priority):**
   - Immediately remove the secrethelpdesk934752.support.futurevera.thm asset from the public network.
   - If essential, place it behind a *firewall* with strict IP whitelisting policies (internal access only or via VPN).
2. **Asset Inventory (High Priority):**
   - Implement a formal Asset Management process to audit, document, and catalog *all hostnames*, subdomains, and services associated with the environment.
3. **Metadata Review (Medium Priority):**
   - Audit and establish policies for SSL/TLS certificate issuance, ensuring that

Subject Alternative Name (SAN) entries do not expose internal or secret *hostnames* to external entities.

4. **Support Services Hardening (High Priority):**
    - In case a similar service is maintained, ensure the application of the latest security patches, implement robust authentication (e.g., 2FA), and protect it with a *Web Application Firewall* (WAF) if externally accessible.